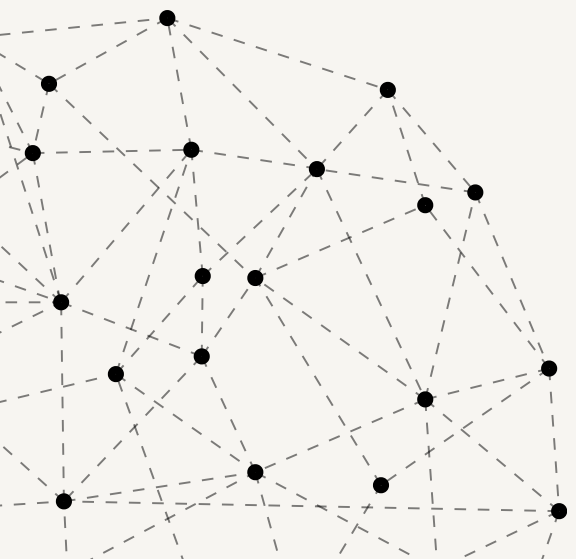
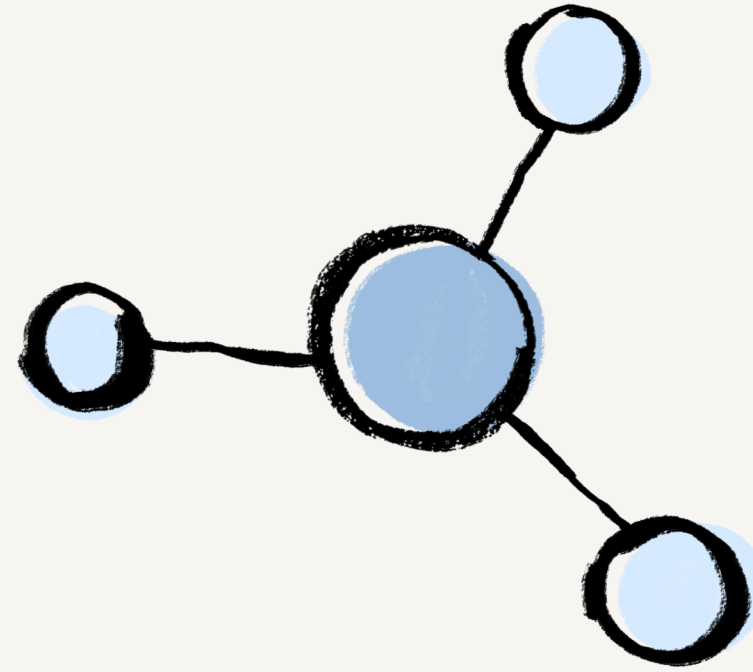


ניתוח טופולוגי וזיהוי פגיעויות בשרשראות אספקה של תוכנה



קורס: אלגוריתמים ברשתות

שמות הצוות: רון בלנקי, מוטי סחרטוב, עידן דהן

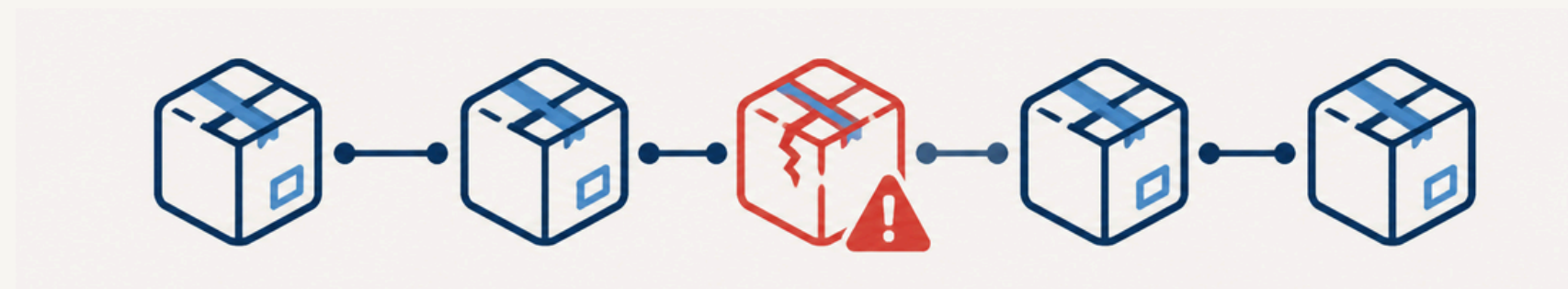
האתגר בשרשראות אספקה של תוכנה

מערכות תוכנה מודרניות מסתמכות על חבילות קוד פתוח ותלויות (Dependencies).

- חבילה פגיעה אחת עלולה להפוך לזוקטור תקיפה רחב המשפיע על פרויקטים וארגונים
- הניתוח הידני בלתי אפשרי בשל עומק, צפיפות וקישוריות הרשת

אירוע מייצג

התקפת Axios במרץ 2026 המחישה כיצד פריצה לחבילה מהימנה אחת הופכת לנקודת כשל מערכתית



המטרה היא מידול שרשרת האספקה כגרף, וחשיפת צווארי הבקבוק ונקודות התורפה

איסוף נתונים ומבנה המטא דאטא

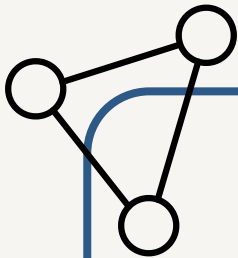
מקור הנתונים הוא Google Open Source Insights API (deps.dev)
עבור חבילת היעד **Flowise** בסביבת npm.

הגרף במספרים

2,150
צמתים (חבילות)

5,035
קשתות (תלויות)

לאחר איחוד לפי שם חבילה



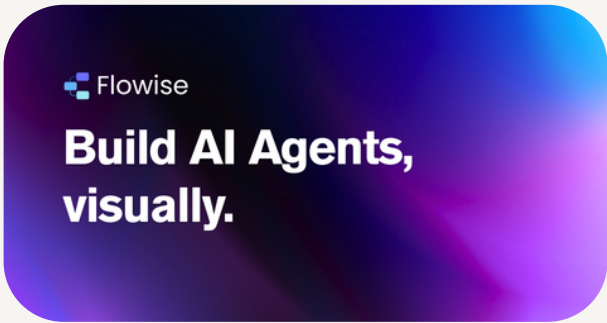
ייצוג הגרף

- **צמתים:** מייצגים חבילות קוד פתוח ייחודיות
- **קשתות:** קשרים מכוונים המייצגים דרישת תלות ישירה או עקיפה.



Flowise AI

פלטפורמת קוד פתוח
פופולרית לפיתוח יישומי
בינה מלאכותית.



שאלות המחקר וגישת הפתרון

1

צווארי בקבוק - אילו חבילות מהוות גשרים הכרחיים?



Betweenness Centrality



2

חבילות תשתית - אילו חבילות נגישות ומשפיעות מבנית?



Harmonic Centrality



3

סיווג קהילות - איך הרשת מתחלקת ומהם צירי התקשורת?



Modularity, Edge Betweenness



4

חוסן ותעדוף אבטחתי - האם חבילות פגיעות מרוכזות
בצווארי בקבוק?



Robustness Simulation, Advisory
Prioritization



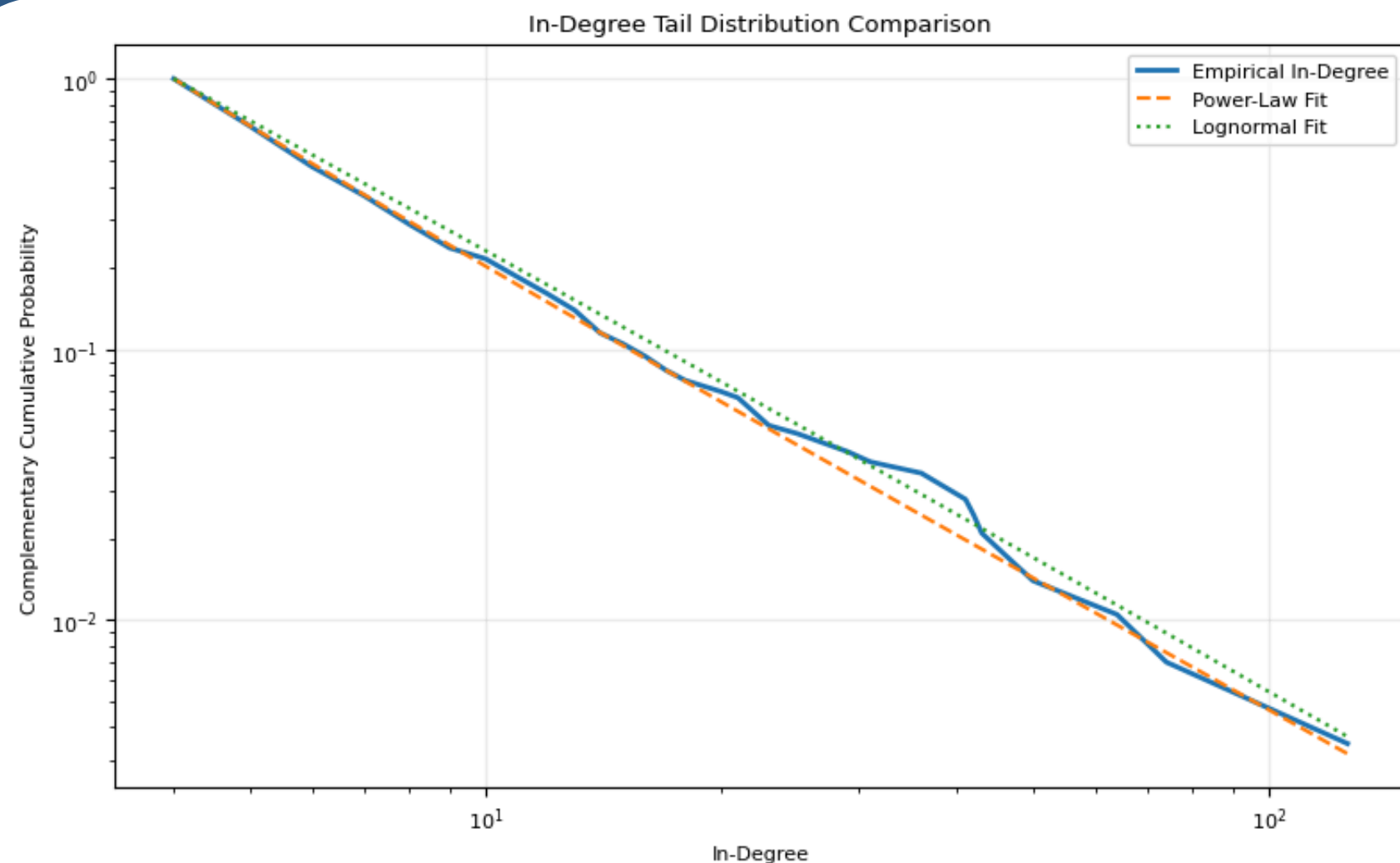
תכונות טופולוגיות - מבנה האקוסיסטם

מקדם התקבצות מול גרף אקראי

$$C/C_r \approx 103.81$$

$$\sigma \approx 102.90$$

התפלגות "זנב כבד"



מאפיין "עולם קטן" - קהילות צפופות מאוד עם מקדם התקבצות גבוה, המקושרות גלובלית

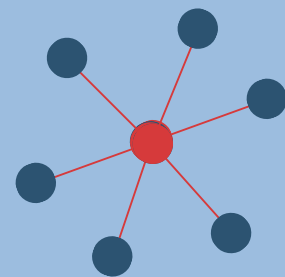
זנב כבד

Power Law עדיף על Exponential, אך Lognormal נשאר חלופה אפשרית

תהליך הפיתוח יעיל, אך תלות בקומץ Hubs מהווה יעד תקיפה מרכזי ונקודת כשל

חבילות קריטיות וצווארי בקבוק

Harmonic Centrality

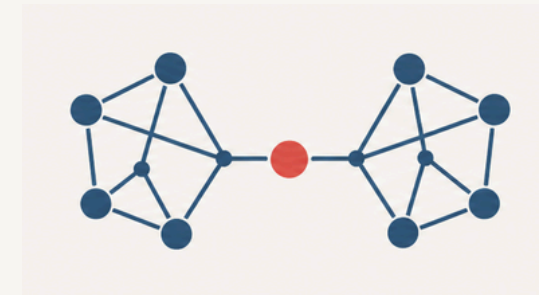


חבילות תשתית נגישות

תשתיות בסיס מקושרות היטב.
סיכון: התפשטות מהירה

	Package Name	Harmonic Centrality
0	tslib	138.40
1	debug	102.38
2	@babel/helper-plugin-utils	78.87
3	ms	78.78

Betweenness Centrality



צווארי הבקבוק

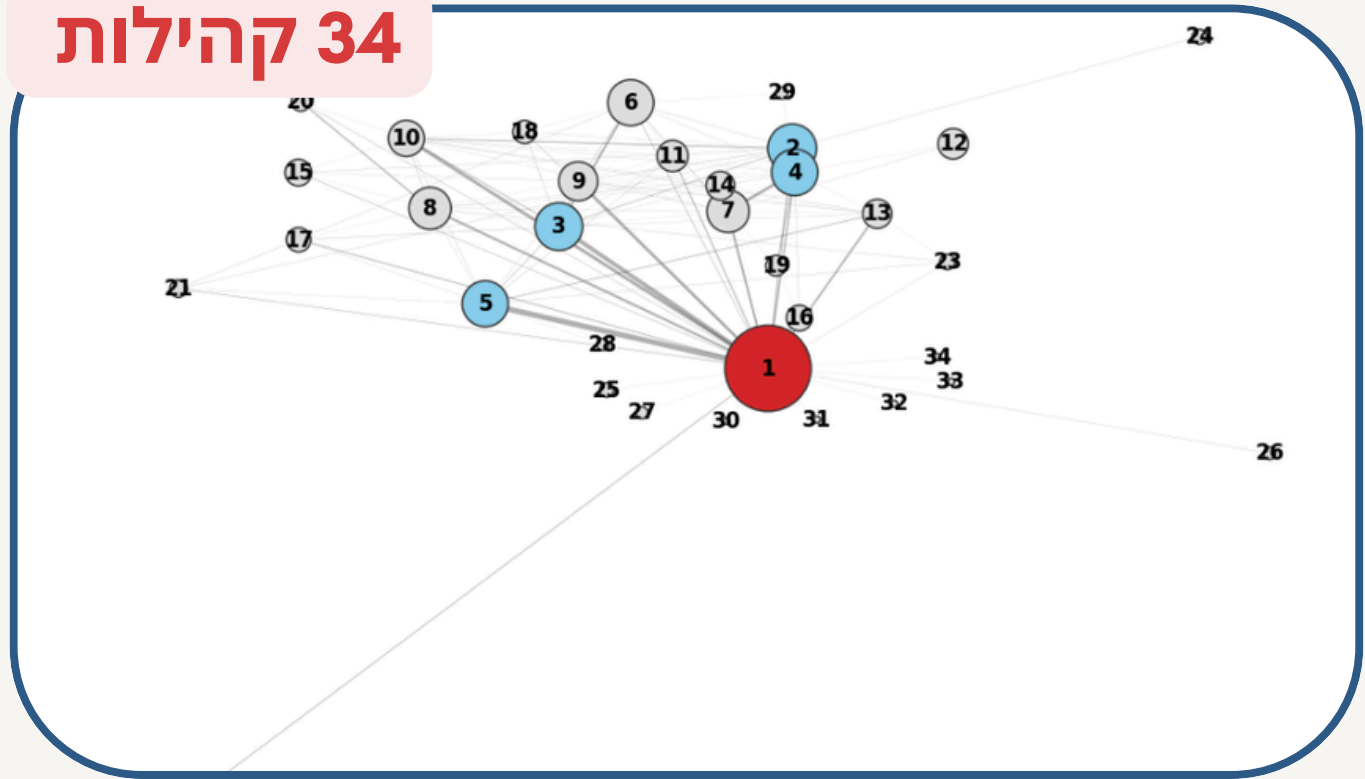
גשרים מבניים בין קהילות.
סיכון: פגיעה בקשירות המבנית

	Package Name	Betweenness Centrality
0	yargs	0.000525
1	@grpc/proto-loader	0.000369
2	form-data	0.000254
3	@grpc/grpc-js	0.000253

כל מדד חושף וקטור סיכון אחר. אבטחה יעילה דורשת הגנה משולבת על 'הגשרים' ועל 'המפיצים'

חקירת נתונים ומבנה קהילות

34 קהילות



מאקרו (Modularity)

קהילה 1 היא הדומיננטית ביותר (474 חבילות)
מאגדת חבילות עם פגיעויות קריטיות כמו:
.form-data I axios

מיקרו (Edge Betweenness)

חישוב Edge Betweenness בתוך קהילת
הליבה, לחשיפת צירי התקשורת הפנימיים
הרגישים ביותר.

	Source Package	Target Dependency	Internal Edge Betweenness
0	flowise	flowise-components	0.001076
1	@grpc/grpc-js	@grpc/proto-loader	0.001017
2	@opentelemetry/otlp-transformer	protobufjs	0.001001
3	@grpc/proto-loader	yargs	0.000846

צמצום מרחב הבעיה לקהילת הליבה, איפשר לאתר את הקשרים הבולטים שפגיעה בהם עלולה לפגוע בקשירות הפנימית

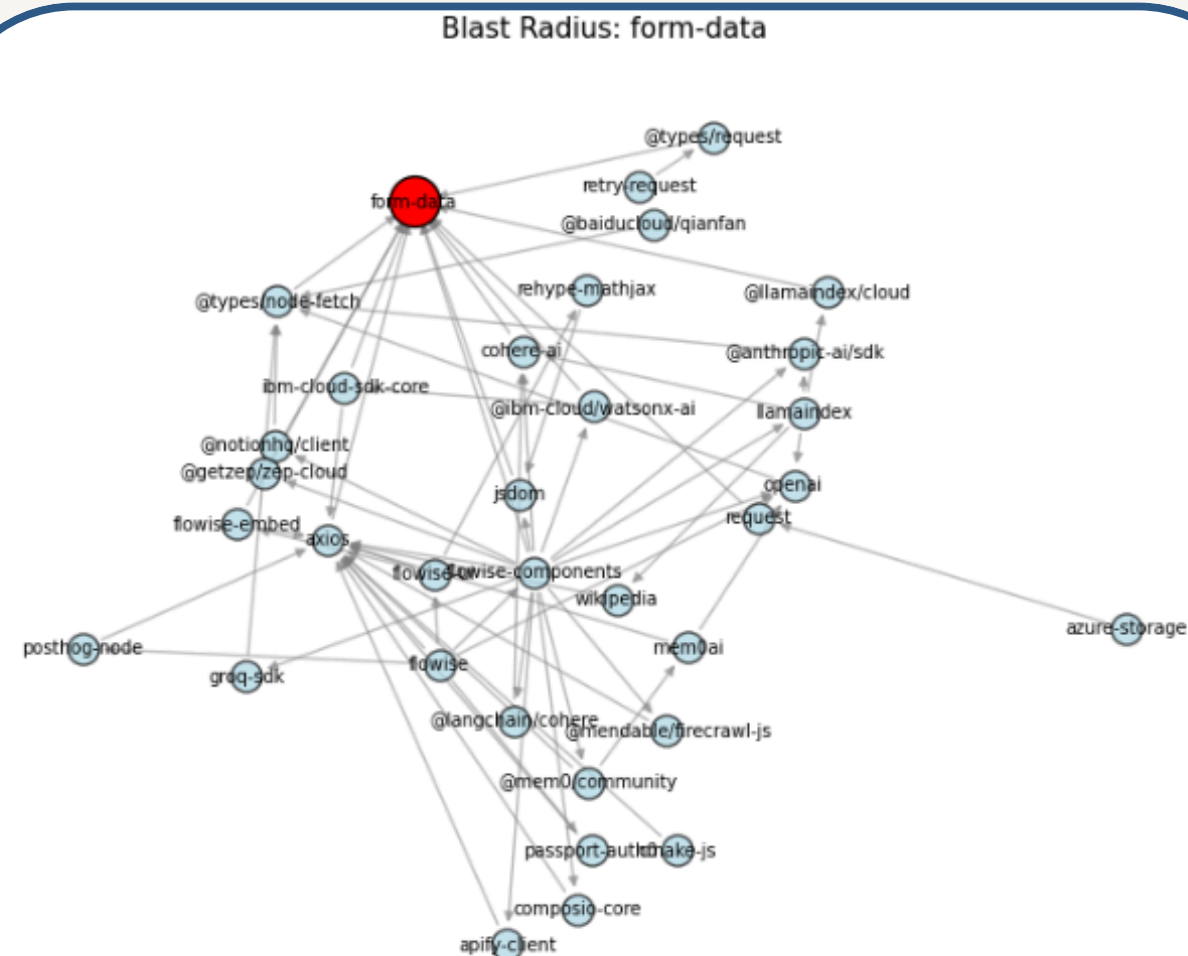
רדיוס ההדבקה וחיזוי התפשטות

נקודת הפריצה

התמקדנו ב form-data צומת אסטרטגי המהווה צוואר בקבוק
(מקום 3 ב-Betweenness) וחשוף כיום לפגיעות אבטחה CRITICAL.

דמיון מבני משלים (Jaccard)

Jaccard זיהה את החבילות בעלות הסביבה המבנית הדומה ביותר: `dotenv`, `qs`, `tough-cookie`

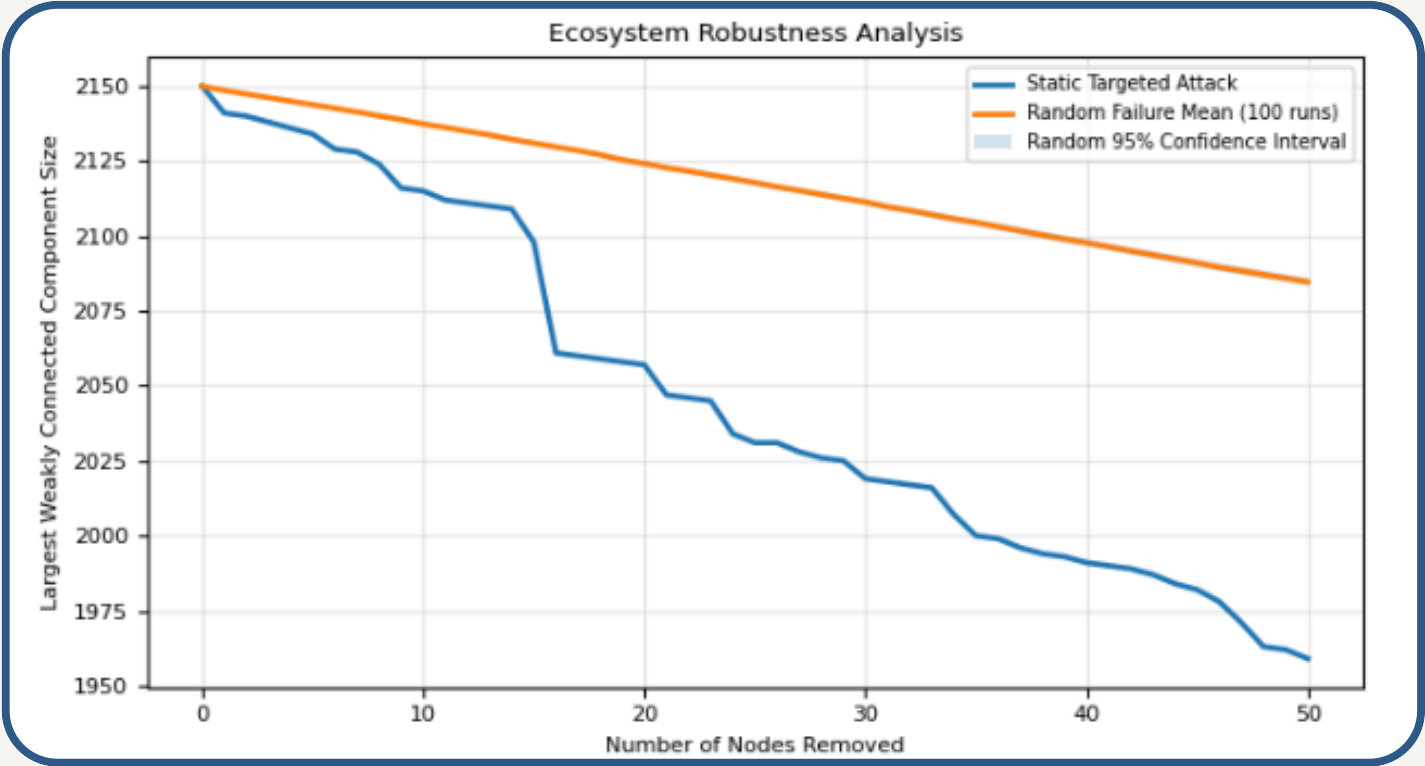


	Compromised Source	Predicted Target	Infection Probability (Jaccard)
0	form-data	qs	0.1818
1	form-data	dotenv	0.1304
2	form-data	tough-cookie	0.1304

המחשה ויזואלית לשרשרת ההדבקה לסביבת הפיתוח בעקבות פריצה

סימולציית קריסה ומבחן המציאות

הסרה אקראית: 3.04% בממוצע התקפה ממוקדת חזקה פי 2.93



קריסת ליבת הרשת תחת התקפה ממוקדת

- הסרת 50 צמתי Betweenness מרכזיים.
- מידת קריסת רכיב הקשירות המרכזי (Giant Component).

הסרת 2.33% מהצמתים ← צמצום של 8.88% בליבת הרשת

	Package Name	Affected_Versions	Advisory_Count	Priority	CVSS	CVSS Version	Severity	Betweenness Centrality	Betweenness Rank
0	form-data	2.3.3, 4.0.0	2		9.4	CVSS_V4	CRITICAL	0.000254	3
1	@grpc/grpc-js	1.13.1	2		7.5	CVSS_V3	HIGH	0.000253	4
2	micromatch	3.1.10	1		5.3	CVSS_V3	MODERATE	0.000168	12
3	protobufjs	6.11.6	11		9.8	CVSS_V3	CRITICAL	0.000110	24
4	@modelcontextprotocol/sdk	1.0.1	1		7.6	CVSS_V4	HIGH	0.000086	34

מבחן המציאות

ניתוח ברמת גרסה מול deps.dev ו־OSV הראה שחבילות פגיעות מרוכזות בצווארי בקבוק

מסקנה: פגיעה במספר קטן של חבילות מרכזיות עלולה להשפיע על חלק משמעותי ממבנה הרשת

סיכום

הושלם עד כה



- בניית הגרף ומידול
- ניתוחי מרכזיות וקהילות
- סימולציית חסינות והצלבת פגיעויות
- חיזוי קישורים ראשוני

הקשיים בתהליך



סיבוכיות חישובית גבוהה למדדי Betweenness גם ברשת גדולה ודלילה

- המרת הגרף ללא-מכוון נדרש עבור אלגוריתם הקהילות, תוך אובדן כיווניות התלויות ברשת

מסקנות מרכזיות

- הרשת מציגה Small-World חזק וזנב כבד
- הסרה ממוקדת פוגעת כמעט פי 3 מהסרה אקראית
- advisories ברמת גרסה מרוכזים בחבילות בעלות Betweenness גבוהה